Week 4 - AWS Organizations (OUs, SCPs, consolidated billing, delegated administrators)

DOP-C02 Domains 2 and 6. Organizations is the base of **every multi-account question**. Typical questions:

1. **Prevent** accounts from disabling CloudTrail, leaving the org or using unapproved Regions = **SCPs**.
2. "Admin can't do X although IAM allows it" = **SCP deny / missing allow somewhere in the OU path**.
3. **Share** discounts across accounts with one bill = **consolidated billing**.
4. Run GuardDuty / Security Hub / Config / StackSets org-wide **without the management account** = **trusted access + delegated administrator**.
5. Only principals in **our organization** may access this bucket = `aws:PrincipalOrgID`.

Part 1 - Structure

```
Organization (o-abc123)
  Root (r-xxxx)                    <- policies here apply to every member account
    Management account (payer)     <- SCPs / RCPs NEVER apply to it
    OU: Security
      Log Archive account
      Security Tooling (Audit)     <- delegated admin for GuardDuty, Security Hub ...
    OU: Infrastructure (Network, Shared Services)
    OU: Workloads
      OU: Prod                     (nested OU)
      OU: Non-Prod
    OU: Sandbox
    OU: Policy Staging             (test SCPs here first)
    OU: Suspended                  (closed / quarantined, deny-all SCP)
```

Element	Key facts
Management account	Creates the org, **pays all bills**, the only account that enables features, creates / invites accounts, registers delegated admins; **SCPs and RCPs don't restrict it** - **no workloads**, minimal users
Member accounts	In **exactly one** organization at a time
Root	Top container; policy here affects all member accounts
OUs	Group accounts; **nested up to 5 levels**; an account is in **one OU**; policies **inherited**
Moving an account	**New OU policies apply immediately**

Feature sets

Feature set	What you get
Consolidated billing only	One bill, shared discounts - **no SCPs or other policies**
All features (default)	Billing **plus** SCPs, RCPs, tag / backup / AI / declarative policies, trusted access, delegated admins

Switching billing-only to all features needs **approval from every invited member account** (created accounts approve automatically).

Created vs invited accounts

	Created (`CreateAccount`)	Invited (existing)
Admin role	`OrganizationAccountAccessRole` created automatically (admin, trusts management account)	**Not created** - create it manually
Root user	No password set (reset or centralized root access)	Existing root user
Joining	Immediate	Must **accept the handshake**

- Leaving needs standalone billing info; block it with SCP `organizations:LeaveOrganization`.
- `CloseAccount`: suspended 90 days (can reopen), limited closures per month.
- Quotas: OU depth 5, **up to 5 SCPs per root / OU / account**, **SCP size 5,120 characters**, account limit is soft.

Centralized root access

- From the management account (or delegated admin): **remove root credentials from member accounts**.
- Privileged root-only tasks with short sessions via `sts:AssumeRoot` (for example unlock a misconfigured S3 bucket policy).

Part 2 - Organization policy types

Policy	Controls	Notes
SCP	**Maximum permissions for principals** (IAM users / roles, **incl. member root user**)	Main guardrail
RCP	**Maximum permissions on resources** (S3, STS, KMS, SQS, Secrets Manager...) for **any caller**	**Data perimeter**
Declarative policies	**Service configuration baseline** (EC2: block public AMI / snapshot sharing, IMDSv2 defaults, VPC block public access, serial console)	Still enforced when new APIs appear; accounts can't override
Tag policies	**Standardise tag keys / values**, optionally **enforce** on resource types	**Don't make tags mandatory** (SCP + `aws:RequestTag`)
Backup policies	**AWS Backup plans** org-wide	
AI services opt-out	Stop AI services storing / using content	
Chat applications policies	Amazon Q Developer in chat apps access	

Each policy type must be **enabled on the root** first.

Part 3 - Service control policies (SCPs)

What SCPs are

- **Guardrails that never grant permissions**; they set the **maximum** IAM can allow in member accounts.
- Apply to **all IAM users and roles in member accounts, including the root user**.
- **Don't apply to**: the **management account**, **service-linked roles**, principals **outside** the org accessing your resources (use **RCPs / resource policies**).

```
Effective permission = allowed by SCPs at EVERY level (root -> each OU -> account)
                       AND allowed by RCPs on the resource (if any)
                       AND allowed by identity policy (+ boundary, session policy)
                       AND no explicit Deny anywhere
```

- **Explicit deny in any SCP on the path wins.**
- An action must be **allowed at every level**: root, each parent OU, the account.
- Default `FullAWSAccess` at every level = IAM alone decides.

Strategies

	Deny list (recommended, default)	Allow list
Setup	Keep `FullAWSAccess`, add **Deny** SCPs	**Remove** `FullAWSAccess`, explicitly **Allow** approved services
Pros	Simple, new services work automatically	Very strict
Trap		Allow needed at **every level**; detaching FullAWSAccess at one OU without an Allow blocks everything below

SCPs now support the **full IAM policy language** (conditions and resources in Allow, NotResource). Exam answers mostly use **Deny with conditions**.

Common SCP patterns

1. Deny leaving the org and disabling security services

```
{ "Effect": "Deny",
  "Action": [ "organizations:LeaveOrganization",
              "cloudtrail:StopLogging", "cloudtrail:DeleteTrail", "cloudtrail:UpdateTrail",
              "guardduty:DeleteDetector", "guardduty:DisassociateFromMasterAccount",
              "config:StopConfigurationRecorder", "config:DeleteConfigurationRecorder",
              "securityhub:DisableSecurityHub" ],
  "Resource": "*" }
```

2. Region restriction (exempt global services and the admin role)

```
{ "Effect": "Deny",
  "NotAction": [ "iam:*", "organizations:*", "sts:*", "route53:*", "cloudfront:*",
                 "support:*", "budgets:*", "waf:*", "globalaccelerator:*" ],
  "Resource": "*",
  "Condition": {
    "StringNotEquals": { "aws:RequestedRegion": [ "us-east-1", "eu-west-1" ] },
    "ArnNotLike": { "aws:PrincipalARN": "arn:aws:iam::*:role/OrgAdminRole" } } }
```

Without the `NotAction` for global services (IAM, STS, CloudFront, Route 53...) those services break - their endpoints are in us-east-1.

3. Protect platform roles from local admins

```
{ "Effect": "Deny",
  "Action": [ "iam:DeleteRole", "iam:PutRolePolicy", "iam:AttachRolePolicy",
              "iam:UpdateAssumeRolePolicy" ],
  "Resource": "arn:aws:iam::*:role/platform-*",
  "Condition": {
    "ArnNotLike": { "aws:PrincipalARN": "arn:aws:iam::*:role/PlatformPipelineRole" } } }
```

4. Others

- **Deny root user actions**: condition `aws:PrincipalArn` like `arn:aws:iam::*:root`.
- **Require IMDSv2**: deny `ec2:RunInstances` if `ec2:MetadataHttpTokens` is not `required`.
- **Require encryption**: `s3:PutObject` without SSE, `ec2:CreateVolume` with `ec2:Encrypted` false, `rds:CreateDBInstance` with `rds:StorageEncrypted` false.
- **Require tags**: deny `ec2:RunInstances` if `Null aws:RequestTag/CostCenter = true`.
- **Deny IAM users / access keys** (force SSO / roles): `iam:CreateUser`, `iam:CreateAccessKey`.
- **Deny expensive instance types**: `ec2:InstanceType`.
- **Suspended OU**: deny `*`.

Troubleshooting "AccessDenied although IAM allows it"

1. Check **all SCPs** on root, every parent OU and the account (explicit deny, or missing Allow in allow-list).
2. Check RCPs, permissions boundaries, session policies, resource policies.
3. The error often says "**with an explicit deny in a service control policy**".
4. Policy simulator / Access Analyzer can include SCPs.

Best practice: test SCPs in a **Policy Staging OU**; attach to **OUs**, not individual accounts.

Part 4 - RCPs and org condition keys

Key	Used in	Meaning
`aws:PrincipalOrgID`	**Resource policies** (S3, KMS, SNS, SQS, Lambda...)	**Caller is in my org** - no account ID list, **new accounts included automatically**
`aws:PrincipalOrgPaths`	Resource policies	Caller in a specific **OU path**
`aws:ResourceOrgID` / `aws:ResourceOrgPaths`	Identity policies / SCPs	**Resource** is in my org (block copies to outside buckets)
`aws:SourceOrgID` / `aws:SourceOrgPaths`	Resource policies for **service principals**	Calling service acts for my org

```
{ "Effect": "Allow", "Principal": "*", "Action": "s3:GetObject",
  "Resource": "arn:aws:s3:::shared-artifacts/*",
  "Condition": { "StringEquals": { "aws:PrincipalOrgID": "o-abc123" } } }
```

RCPs are attached in Organizations and limit access to member-account resources by **any caller**. Example: deny `s3:*` and `sts:AssumeRole` when `aws:PrincipalOrgID` is not `o-abc123` (and not an AWS service) - **even a bad bucket policy can't expose data outside the org**. Like SCPs: never grant, no effect on the management account or service-linked roles. **SCP = what my principals can do; RCP = who can touch my resources.**

Part 5 - Consolidated billing

Feature	Detail
One bill / payment method	Management account pays for all members
Combined usage	Tiered pricing (S3, data transfer) uses **total org usage** - volume discounts
RI and Savings Plans sharing	Unused discounts **apply to matching usage in other accounts**; on by default; **can be turned off per account** in management account billing preferences
Free tier	**One per organization**
Cost visibility	**Cost Explorer**, **Budgets** (account, OU, tag, cost category), **Cost and Usage Report / Data Exports** (S3 + Athena), **Cost Categories**, **cost allocation tags** (activated in the **management account**), Cost Anomaly Detection
Member view	Members see their own costs; management account sees all; billing conductor for chargeback

- "Several accounts run steady EC2" = **buy Savings Plans / RIs centrally**, shared via consolidated billing.
- "Charge back costs to teams" = **cost allocation tags + Cost Categories + CUR / Data Exports**.

Part 6 - Trusted access and delegated administrators

Trusted access

Lets a service **work across the organization** (service-linked roles in members, read org structure). Enable from the **service console** in the management account (preferred) or `organizations enable-aws-service-access`.

Service	Org integration
CloudTrail	**Organization trail** to a central bucket; **members can't modify or delete it**
AWS Config	**Aggregator**, **org Config rules**, **org conformance packs**
Security Hub / GuardDuty / Macie / Inspector / Detective	**Auto-enable for new accounts**, central findings
Firewall Manager	Org-wide WAF, Shield, SG, Network Firewall policies
IAM Identity Center	SSO with **permission sets** per account
IAM Access Analyzer	Zone of trust = organization
CloudFormation StackSets	**Service-managed**, OU targets, auto-deployment
Control Tower	Landing zone, controls, Account Factory
AWS Backup	Backup policies, cross-account monitoring
AWS RAM	**Share with org / OUs without invitations** (subnets, Transit Gateway, Resolver rules)
Service Catalog	Share portfolios with org / OUs
Systems Manager	Quick Setup, patch policies, Explorer org-wide
AWS Health	**Organizational view**
Others	Trusted Advisor, Compute Optimizer, Cost Optimization Hub, License Manager, Audit Manager, CloudWatch cross-account observability

Delegated administrator

- **Register a member account to administer a service org-wide**: **Security Tooling / Audit** for GuardDuty, Security Hub, Macie, Inspector, Detective, Access Analyzer, Config, Firewall Manager; **Infrastructure** for StackSets, Systems Manager, IPAM.
- Why: **least use of the management account** (separation of duties, smaller blast radius - SCPs don't protect the management account).
- How: from the **management account** in the service console or `organizations register-delegated-administrator --account-id ... --service-principal ...`; trusted access required.
- Limits vary: many services allow **one** delegated admin (GuardDuty, Security Hub); StackSets up to **5**.
- **Delegated admin for Organizations itself**: **resource-based delegation policy** (`organizations put-resource-policy`) lets a member account **read the org and manage policies** (SCPs, tag policies) without signing in to the management account.

Automation hooks

Organizations API events (CreateAccount, MoveAccount) are in **CloudTrail in us-east-1**; **EventBridge in us-east-1** can trigger Lambda / Step Functions to baseline new accounts (or use StackSets auto-deployment / Control Tower).

Part 7 - Multi-account OU design

OU	Accounts / purpose	Typical SCPs
Security	**Log Archive** (immutable logs), **Security Tooling / Audit** (delegated admin)	Deny deleting logs, deny disabling security services
Infrastructure	**Network** (TGW, egress, DNS), **Shared Services** (directory, CI, artifacts)	Network changes only by network team
Workloads	Prod / Non-Prod application accounts	Region restriction, encryption, IMDSv2, tags
Sandbox	Experiments	Budgets, deny expensive services, no corporate network
Deployments	CI/CD tooling accounts	
Policy Staging	Test new SCPs	
Suspended	Closing / quarantined	**Deny all**
Exceptions / Transitional	Special cases, migrations	

Management account: MFA on root, few users (Identity Center federation), **no workloads**, org / billing tasks only, **delegate everything else**.

Part 8 - Exam traps

Trap	Truth
SCP grants access	**Never grants**; IAM must allow
SCP blocks management account	**Doesn't apply to the management account**
SCP restricts service-linked roles	**No**
SCP restricts member root user	**Yes**
Allow in account-level SCP is enough	Must be allowed at **every level**
Removed FullAWSAccess, everything broke	Allow-list needs **explicit Allows** at that level
Region-deny breaks IAM / CloudFront / Route 53	**Exempt global services** with `NotAction`
Admin pipeline blocked by SCP	Exempt with `ArnNotLike aws:PrincipalARN`
SCPs on billing-only org	Need **all features** (invited members approve)
Invited account has OrganizationAccountAccessRole	**Only created accounts**; create manually
Prevent leaving the org	**SCP deny** `organizations:LeaveOrganization`
Tag policy makes tags required	**No**; **SCP +** `aws:RequestTag`
All org accounts read a bucket without IDs	`aws:PrincipalOrgID`
Block outside access even with bad bucket policies	**RCP**
EC2 settings that survive new APIs	**Declarative policy**
Members disable org CloudTrail	**Can't**
Free tier per account	**One per organization**
Business unit keeps its own RIs	**Turn off RI / SP sharing** for that account
Security admin in management account	**Delegated administrator** (Security Tooling)
New accounts get GuardDuty / Security Hub	**Auto-enable** from the delegated admin
Manage SCPs without management account	**Delegated admin for Organizations** (resource policy)
Remove member root passwords	**Centralized root access** (`sts:AssumeRoot`)
React to new accounts	**EventBridge us-east-1** or StackSets auto-deployment / Control Tower
Share subnets / TGW without invitations	**RAM with Organizations sharing**
More than 5 SCPs on an OU	Combine statements or attach at parent levels

Part 9 - Hands-on lab (about 60 minutes)

Use a **dedicated test management account**. Creating accounts is free, but **closing accounts is limited and slow**.

Lab 1 - Org, OUs, account

1. **Create organization** (all features); note the **org ID** and **root ID**.
2. OUs: `Security`, `Workloads` -> `Prod`, `Sandbox`, `PolicyStaging`, `Suspended`.
3. **Create a member account** (email alias `you+sandbox1@example.com`); move it to `PolicyStaging`.
4. **Switch role** into it with `OrganizationAccountAccessRole`: admin access.

Lab 2 - SCPs

1. Enable the **SCP policy type**; note **FullAWSAccess** everywhere.
2. Attach `DenyLeaveAndSecurityChanges` (pattern 1) and `RegionRestrict` (pattern 2) to **PolicyStaging**.
3. In the member account: create a bucket in a blocked Region = **explicit deny in a service control policy**; IAM still works; `leave-organization` denied.
4. Management account: the same bucket creation **works** (not affected).
5. Allow-list: on `Sandbox` detach `FullAWSAccess`, attach an SCP allowing only `s3:*` and `cloudwatch:*`; move the account there; only those work. **Re-attach FullAWSAccess.**

Lab 3 - Tag policy and tag-requirement SCP

1. Tag policy: `CostCenter` values `["100","200"]`, enforced for `ec2:instance`, on `PolicyStaging`.
2. SCP: deny `ec2:RunInstances` when `aws:RequestTag/CostCenter` is null.
3. Launch without tag = denied by SCP; `CostCenter=999` = blocked by tag policy; `CostCenter=100` = allowed. Terminate.

Lab 4 - Org services and delegated admin

1. **Organization trail** in CloudTrail; in the member account try to stop it: not allowed.
2. **Access Analyzer** with zone of trust = organization.
3. GuardDuty (or Config / Security Hub): **member account as delegated admin**; from it see org accounts and **auto-enable new accounts**; `organizations list-delegated-administrators`.
4. Bucket policy `Principal: *` with `aws:PrincipalOrgID = o-xxxx`: member account can read, outside account denied.

Lab 5 - Billing

Cost Explorer by linked account, **Billing preferences** (RI / SP sharing), **cost allocation tags** (activate `CostCenter`), a **Budget** filtered to the member account.

Cleanup: delete trail, analyzer, GuardDuty delegation, bucket, policies, tag policy; move the account to `Suspended`; closing it is optional (90-day suspension, monthly limits).

Part 10 - Check yourself

Questions

1. What can the management account do that members can't, and why no workloads there?
2. What do you lose with consolidated billing only, and what's needed to switch to all features?
3. Do SCPs grant permissions? Who do they apply and not apply to?
4. How are SCPs evaluated across root, OU and account?
5. Deny-list vs allow-list - the allow-list risk?
6. Region-restriction SCP that doesn't break global services or the admin pipeline?
7. An invited account has no OrganizationAccountAccessRole - why and fix?
8. Stop accounts leaving the org and disabling CloudTrail / GuardDuty / Config?
9. Tag policy vs SCP - which makes a tag mandatory?
10. Every org account reads a bucket without listing IDs?
11. SCP vs RCP, and when to use an RCP?
12. Three consolidated billing benefits; how many free tiers per org?
13. A business unit wants its RIs used only by its own account?
14. What is a delegated administrator, why, two examples?
15. React automatically when a new account is created?

Answers

1. Create / invite accounts, enable features and policy types, register delegated admins, pay; **SCPs / RCPs don't restrict it** - minimal access, no workloads.
2. Lose **SCPs, other policies, trusted access / delegated admins**; switching needs **approval from every invited member**.
3. **No**, only limit; apply to **all member IAM principals incl. root**; not to the **management account, service-linked roles or external principals**.
4. **Explicit deny anywhere wins**; an Allow must exist at **every level** and in IAM.
5. Deny-list keeps FullAWSAccess + Denies; allow-list removes it - must **allow at every level** or everything below is blocked.
6. Deny with `NotAction` **for global services**, condition `aws:RequestedRegion` **not in list**, `ArnNotLike` `aws:PrincipalARN` for the admin role.
7. Only **created** accounts get it; **create the role manually** trusting the management account.
8. **SCP** denying `organizations:LeaveOrganization` and the stop / delete actions (+ org trail).
9. Tag policy standardises / enforces values; **SCP with** `aws:RequestTag` **Null** makes it mandatory.
10. Bucket policy with `aws:PrincipalOrgID`.
11. SCP limits **principals**; RCP limits **resources** for any caller; RCP for a **data perimeter**.
12. One bill, combined volume discounts, **RI / SP sharing**; **one free tier per org**.
13. **Turn off RI / Savings Plans sharing** for that account (management account billing preferences).
14. Member account administering a service org-wide, to **minimise management account use**; Security Tooling for GuardDuty / Security Hub, Infrastructure for StackSets.
15. **EventBridge (us-east-1)** on Organizations CloudTrail events (CreateAccountResult) -> Lambda / Step Functions; or StackSets auto-deployment / Control Tower.

Quick memory summary

- **Organization** = management account (pays, **not restricted by SCPs**, no workloads) + members in **OUs** (nested up to 5, inherited); **all features** for policies; invited members approve.
- **Created accounts** get **OrganizationAccountAccessRole**; invited ones don't.
- **SCPs**: guardrails, **never grant**, apply to member principals **incl. root**, not management account or SLRs; explicit deny wins; Allow at **every level**; deny-list vs allow-list; patterns: leave-org / security, **Region restriction with NotAction**, protect roles, require tags / encryption / IMDSv2.
- **RCPs** = resource data perimeter; `aws:PrincipalOrgID`; **tag policies** standardise (SCP requires); **declarative policies** for EC2 baselines.
- **Consolidated billing**: one bill, volume discounts, **RI / SP sharing** (per-account off), one free tier, Cost Explorer / Budgets / CUR / cost allocation tags.
- **Trusted access** (org CloudTrail, Config aggregator, GuardDuty / Security Hub auto-enable, StackSets, RAM, Identity Center); **delegated admin** keeps people out of the management account; centralized root access; EventBridge us-east-1.